

보안 커뮤니케이션 중간고사

일시/장소 : 4.23(목), 12:00~13:00 / 818호

시험범위

- 1) Shannon과 Weaver의 커뮤니케이션 프레임워크
- 2) [ISO 31000 : 2018 리스크 관리]의 프로세스
- 3) [ISO27001:2022 정보보호경영시스템]의 HLS 목차
- 4) [ISO22361:2022 위기관리시스템]의 원칙과 프레임워크, 프로세스
- 5) 위험과 위기의 차이?

Sahnnon과 Weaver

커뮤니케이션 모델 1949년 Bell 연구소의 Calude Shannon과 Warren Weaver가 고안.

-> 의사소통은 메시지의 발신과 수신, 혹은 정보를 한곳에서 다른곳으로 전송하는 것을 기본개념으로 함.

새로운 모형은 전파와 전화 기술을 반영하도록 설계

발신자(Sender) : 사람이 말하는 전화기 부분

채널(Channel) : 전화 그 자체. 전화기가 연결된 통신선도 포함. 메시지가 지나가는 통로

수신자(Receiver) : 다른 사람이 듣는 전화기 부분

잡음(Noise) : 종종 방해할 일으키는 것도 잡음으로 간주하여 인정. 신호와 결핍(끊어짐)도 포함.

모든 방해요소

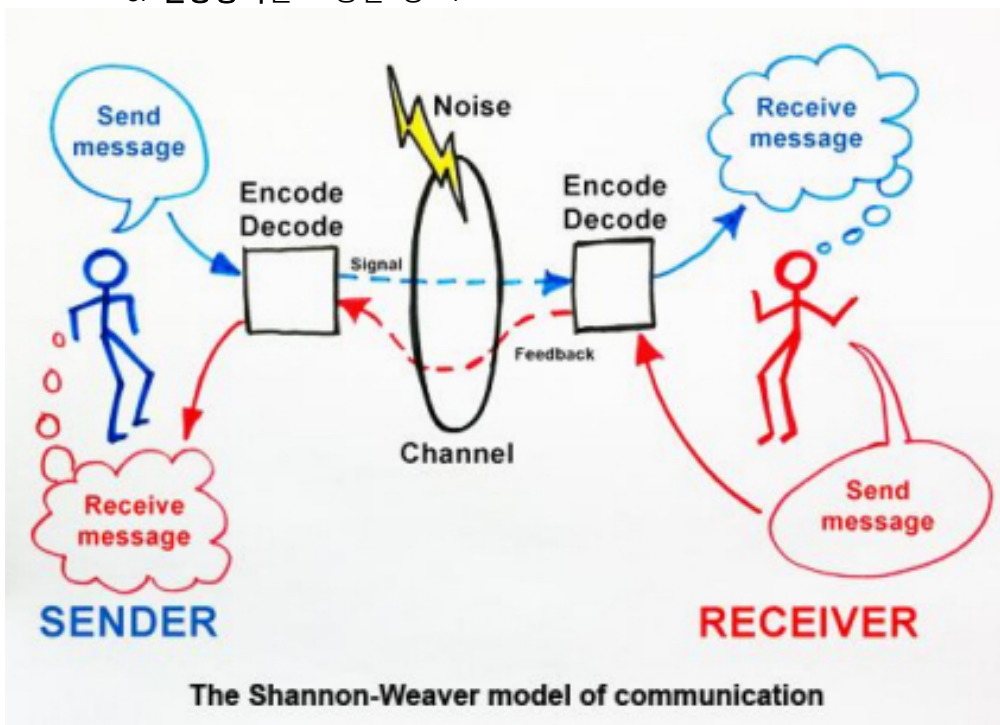
부호화(Encode) : 생각이나 의미를 전달 가능한 신호로 바꾸는 과정

복호화(Decode) : 전달된 신호를 의미로 바꾸는 과정이야.

피드백(Feedback) : 메시지를 받은 사람이 다시 반응을 보내는 것. e.g. 대답하기, 고덕이기, 답장하기

- 의의 :
- 1. 정보통신 이론의 발전에 기여
 - 2. 커뮤니케이션 연구의 기초를 마련
 - 3. 통신 시스템 설계에 중요한 영향

- 한계 :
- 1. 인간의 심리적, 사회적 요인을 미고려
 - 2. 메시지의 의미 해석을 간과
 - 3. 일방향적인 소통만 강조.



[ISO 31000 : 2018 리스크 관리]의 프로세스

$Risk = Asset \times Threat \times Vulnerability - Countermeasuer$
위험 = 자산 x 위협 x 취약성 - 보호대책

ISO31000 : 위험 관리에 대한 국제 표준.
조직이 다양한 위험(Risk) 식별하고 평가하며 이를 효과적으로 관리할 수 있도록 돕는 프레임워크와 지침 제공
조직이 직면할 수 있는 다양한 위험을 식별하고 관리, 부정적인 영향을 최소화, 기회는 최대화
위험 관리를 조직 전략 및 의사결정 과정에 통합시켜 장기적인 성공 도모

1. Scope, Context & Criteria

Scope :
Context : 기업의 처한 환경 등 맥락. e.g. 자금상황 등..
Criteria : 요구사항이 있는가? 거버넌스같은 기준이 적용되어야 하는 기준이 있는가?

2. Risk Assessment 위험 진단

- 1) Risk Identification 위험 식별 : 조직에 영향을 줄 수 있는 위험을 찾아내고 정의하는 과정
 Asset * Vurnerability * Threat 식별
- 2) Risk Analysis 위험 분석 : 식별된 리스크를 평가하기 위해서 위험의 수준을 파악하는 과정.
 e..g. 척도를 만드는 과정. 5점 만점으로 하자.
- 3) Risk Evaluation 위험 평가 : 위험을 점수화 시켜서 계산하는 과정
 e.g. 이 위험이 5인가? 4인가?

3. Risk Treatment : Assesment(진단)이 되었으면 그 리스크를 처리해야 하는데, 처리하는 과정
감소, 회피, 전가, 수용 등 구체적인 계획 실행

+ Communication & Consultation Recording & Report Monitoring & Review



ISO(the International Organization for Standardization) - HLS(High Level Structure)

4.조직상황	5. 리더십	6. 기획	7. 지원	8. 운용	9. 성과평가	10. 개선
4.1 조직과 조직상황 이해	5.1 리더십과 의지표명	6.1 리스크와 기회를 다루는 조치	7.1 자원	8.1 운용기획 및 관리	9.1 모니터링, 측정, 분석 및 평가	10.1 일반사항
4.2 이해관계자의 니즈와 기대 이해	5.2 방침	6.2 목표와 목표 달성 계획	7.2 역량/적격성		9.2 내부심사	10.2 부적합 및 시정조치
4.3 ○○ 시스템의 적용 범위 결정	5.3 조직의 역할, 책임 및 권한		7.3 인식		9.3 경영검토	10.3 지속적 개선
4.4 ○○ 경영 시스템			7.4 의사소통			
			7.5 문서화된 정보			

☞ [보안업무규정] 의식교육, 불시점검, 강화지시, 일제조사, 핵심 프로세스 통제, 세척/매뉴얼 개정, 전문가 배치, 자체감사, 보안사고 후속조치

4. 조직 상황 Context

4.1 조직과 조직상황 이해:

조직의 목적에 영향을 미치는 내부 이슈(역량, 문화)와 외부 이슈(법규, 경제, 기술)를 파악합니다.

4.2 이해관계자의 니즈와 기대 이해:

고객, 직원, 정부 등 관련 있는 사람들이 조직에 무엇을 원하는지 파악합니다.

4.3 시스템의 적용 범위 결정:

경영시스템을 우리 회사의 어느 부서나 제품에 적용할지 경계를 정합니다.

4.4 경영 시스템:

파악된 상황을 바탕으로 프로세스를 수립하고 운영합니다.

5. 리더십 Leadership (거버넌스)

5.1 리더십과 의지표명:

경영진이 시스템 운영에 적극적으로 참여하고 자원을 지원하겠다는 의지를 보여줍니다.

5.2 방침 Policy:

조직이 나아가야 할 방향(품질 방침, 환경 방침 등)을 **명문화**합니다. 정보보안에 관한 룰 나열.

5.3 조직의 역할, 책임 및 권한:

누가 무엇을 책임지고 어떤 권한을 가질지 명확히 배분합니다.

6. 기획 Planning

6.1 리스크와 기회를 다루는 조치:

발생할 수 있는 부정적 위험(리스크)은 줄이고, 긍정적 기회는 활용하기 위한 대책을 세웁니다.

Risk Assessment, Risk Treatment -> 문서화하기

6.2 목표와 목표 달성 기획:

구체적이고 측정 가능한 목표를 정하고, 이를 어떻게 달성할지 계획합니다.

PDCA 기반 : Plan Do Check Act(계획 실행 점검 조치/개선)

7. 지원 Support

7.1 자원:

물적 자원(돈) + 인적 자원

7.2 역량/적격성:

자원이 적합한가? CCTV는 제대로 보이는 CCTV인가? 제대로 된 보안 요원인가?

7.3 인식:

모든 구성원에게 인식이 되어 있는가? 보안 교육이 되어 있는가?

7.4 의사소통 Communication:

의사소통이 적절히 이루어져야 한다. 공지, 회의 등등의 형식.

7.5 문서화된 정보:

필요한 문서와 기록을 만들고 효율적으로 관리합니다. CCTV 다는데 필요한 것들을 검토했다는 문서

8. 운용 Operation

8.1 운용기획 및 관리:

기획이 되고 자원이 투입이 되었으니 운영을 해야함.

-> 여기서도 Risk Assessment를 해야 함

9. 성과 평가 (Performance Evaluation)

9.1 모니터링, 측정, 분석 및 평가:

성적을 매김. 관리자가 점검.

9.2 내부 심사 (내부 감사, Internal Audit)

정기적인 모니터링이 아니라, 일회성으로 연 1회 감사를 진행하는 심사

9.3 경영검토:

경영진 레벨에서 모니터링이나 측정 분석된 결과들을 들여다보는 것.

경영진 회의에서 ISO 27001이나 ISMS-P 같은 것을 한다고 다뤄줘야만 예산이 내려온다.

10. 개선

10.1 일반사항:

고객 만족을 높이기 위해 개선이 필요한 부분을 찾습니다.

10.2 부적합 및 시정조치:

잘못된 부분(부적합)이 발생하면 원인을 파악하여 재발하지 않도록 조치합니다.

10.3 지속적 개선:

당장 고치는 것이 아니고, 지속해서 개선해야 되는 사항.

[ISO22361:2022 위기관리시스템]의 원칙과 프레임워크, 프로세스

왜 배우는가?

위기는 갑자기 시작되지만 대응 역량은 미리 만들어진다.
초기 몇 분~ 몇 시간이 피해 규모를 크게 좌우함.
리더십, 의사결정, 소통 구조가 동시에 작동해야 함.

-> ISO 22361은 이를 조직 역량 관점에서 정리한 표준이다!

원칙 -> 프레임워크 -> 프로세스

원칙 : 무엇을 기준으로 판단할 것인가를 정의

프레임워크 : 누가 어떤 구조로 움직일 것인가? 시간의 흐름과 상관없이 유지되는 자원이나 예산, 조직을 의미.

프로세스 : 위기, 전·중·후에 무엇을 하는가, 시간 전개에 따라 움직이는 순서.

Principles 무엇을 기준으로 판단할 것인가

Framework 누가 어떤 구조로 움직일 것인가

Process 위기 전·중·후에 무엇을 할 것인가

★Risk Management vs Crisis Management★ 한 문제!

Risk Management 위험 관리

사전 예방 중심
위험 식별·분석·평가
발생 가능성/영향 감소
일상 운영의 계획적 관리

Crisis Management 위기 관리

현실화된 위협에 대한 대응 중심
불확실한 정보 속 신속한 판단
핵심 기능 유지와 이해관계자(투자자, 주주, 경영진, 하도급...) 보호
리더십·소통·협업의 동시 작동
대응 후 회복과 학습까지 포함



-> 위험이 현실화되면 리스크관리의 언어만으로는 부족하고, 위기관리의 의사결정 체계가 필요해짐
실무 포인트: 위기 상황에서는 정답보다 “시간 내에 충분히 좋은 판단”이 중요함

위기관리시스템

외부 링 - Principle 원칙

위기관리의 판단 기준

Get Some Rest, Don't Cry, Eat Lunch.

Governance: 경영진에 의해서 권한, 책임, 의사결정 기준을 명확히 정해져야 한다.

Strategy: 단기 진화와 장기 방향을 함께 봐야 한다. 위기가 닥쳤을 때 어떻게 하지?

Risk: 불확실성과 잠재적 파급효과를 계속 고려해야 한다. 제주도 사업장엔 태풍이 올 수 있겠구나

Decision making: 정보가 제한돼도 우선순위를 세워 판단해야 한다.

Communication: 내부·외부에 일관된 메시지를 전달해야 한다.

Ethics: 법적 준수뿐 아니라 신뢰와 공정성도 중요하다.

Learning: 사후평가로 조직 역량을 계속 높여야 한다.

Principle 중 Communication의 중요성

정보 불일치의 위험성:

위기 상황에서는 정보의 부족보다 정보가 불일치하는 것이 더 큰 혼선을 만든다.

대응 자체의 정렬:

커뮤니케이션은 단순히 일어난 일을 설명하는 것이 아니라, **조직의 대응 그 자체를 정렬**하는 기능
신뢰 유지: 내부와 외부 메시지가 일관되어야 조직의 신뢰를 유지할 수 있다.

대상(Who)	내용(What)
내부 구성원 경영진 및 의사결정자 대응기관·협력기관 고객·이해관계자·언론	현재 상황에서 무엇이 확인되었는지 무엇이 아직 불확실한지 조직이 무엇을 하고 있는지 수신자가 지금 무엇을 해야 하는지
시점(When)	원칙(How)
초기 인지 직후 가능한 한 빠르게 상황 변화에 맞춰 반복적·주기적 연속적으로	정확성·일관성·적시성 이해관계자 맞춤형 메시지 단일 창구와 승인 체계 기록 유지와 사후 검토

-> ISO 22361에서 커뮤니케이션은 단순 전달기술이 아니라,
위기 상황에서 의미를 정리하고 행동을 조정하며 신뢰를 유지하는 핵심 관리 기능

중간 링 - Framework 프레임워크

조직이 위기에 움직이는 방법

LSCC

- Leadership** : 방향을 제시하고 책임 있게 결정을내리는 리더십.“누가 최종 판단을 내리는가?”를 분명히 해야 한다
- Structure** : 위기관리팀, 보고라인, 대변인, 지원부서 등 **역할과 연결 구조를 사전에 정리**한다.
- Culture** : 문제를 숨기지 않고 조기에 공유하는 문화, 안전, 윤리를 우선하는 **조직 분위기가 중요하다.**
- Competence** : **훈련·시뮬레이션·학습**을 통해 실제 위기 상황에서도 역할 수행이 가능한 **역량을 확보**한다.
-> FTX 실제훈련 등을 통해서 함.

내부 링 - Process 프로세스

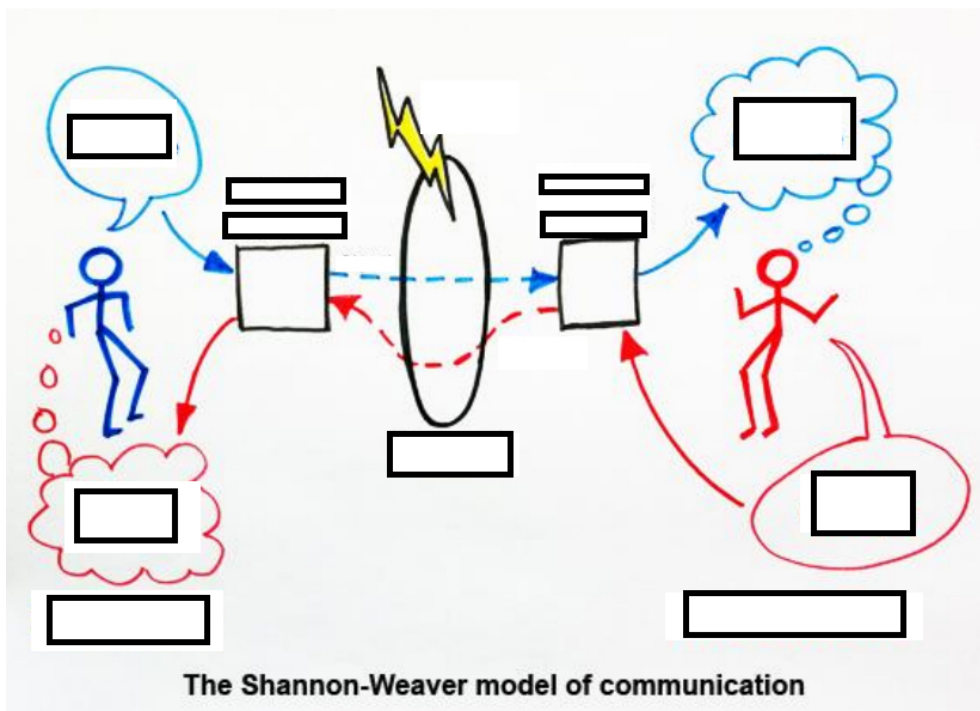
위기 전·중·후의 실행 흐름

AAPRR

- Anticipation**: 가능한 위기 징후를 미리 상상하고 감지
- Assessment**: 정보 신뢰도와 영향 범위 판단, 평가.
- Prevention**: 위기로 번지지 않도록 확산 방지. Treatment라고 볼 수도 있음.
- Preparedness**: 계획, 훈련, 자원, 매뉴얼 준비
- Response**: 실제 위기 발생 시 기능 유지하며 대응
- Recovery**: 운영과 평판, 신뢰 회복

원 내부

Continual improvement : 모든 단계에서 사후평가·훈련·피드백을 통해 **반복적으로 개선**



ISO(the International Organization for Standardization) - HLS(High Level Structure)

4.	5.	6.	7.	8.	9.	10.
4.1	5.1	6.1	7.1	8.1	9.1	10.1
4.2	5.2	6.2	7.2		9.2	10.2
4.3	5.3		7.3		9.3	10.3
4.4			7.4			
			7.5			

